

Fecha: 22 de Septiembre del 2026

CNO 4: CIBERSEGURIDAD

ACTIVIDAD 9 LAB: TRAVERSAL SEQUENCES STRIPPED NON-RECURSIVELY

Documentación

Maestro: Servando López Contreras

Alumno: Quetzal Olin Rodríguez Jiménez

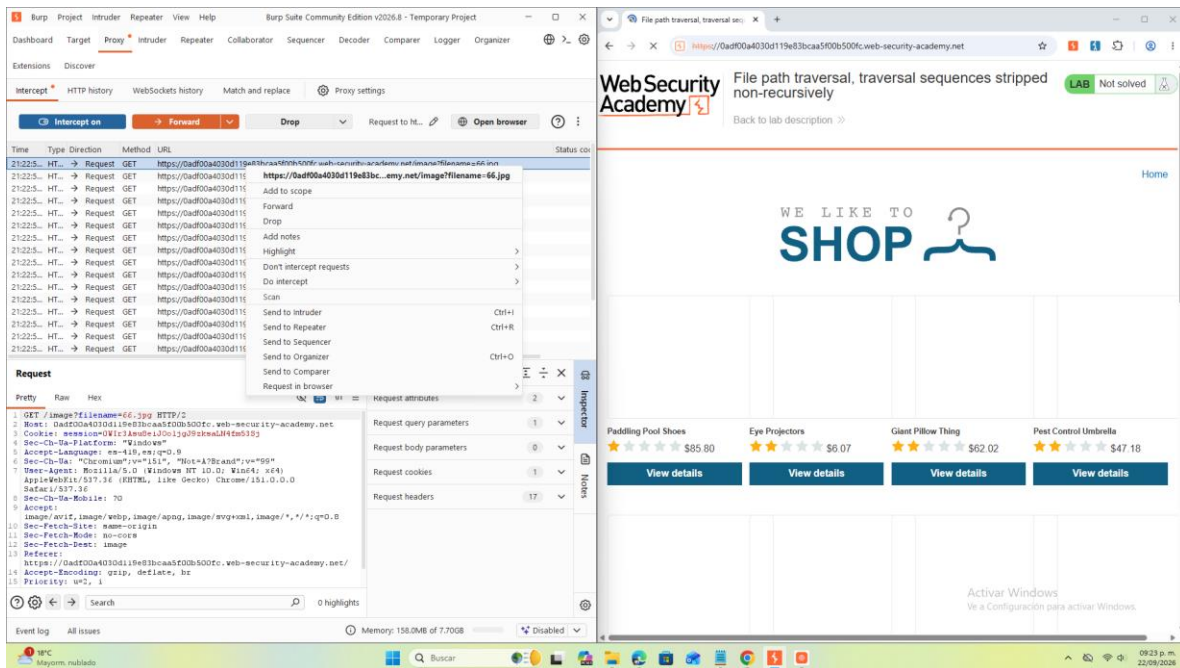
Contenido

OBJETIVO.....	2
AMBEINTE DE LABORATORIO	3
ANÁLISIS DE LA VULNERABILIDAD Y FORMA DE RESOLUCIÓN.....	4
COMANDOS UTILIZADOS	5
RESULTADOS	6
CONCLUSIONES	6

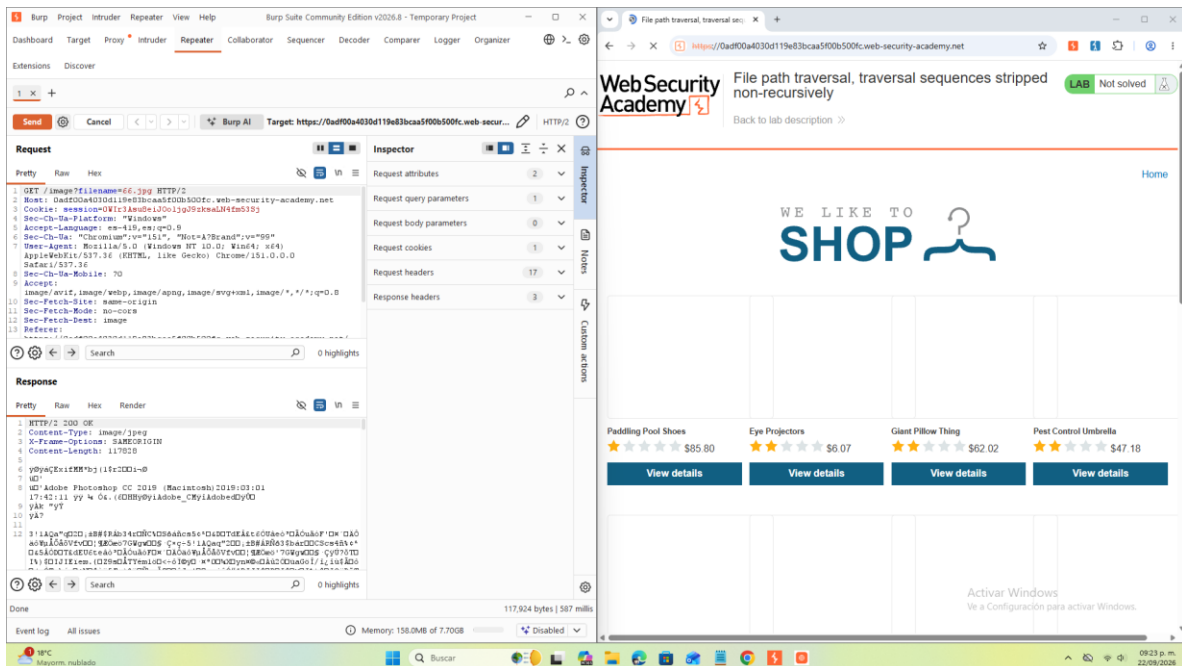
OBJETIVO

El objetivo de este laboratorio es explotar una vulnerabilidad de File Path Traversal (también conocido como Directory Traversal) en la sección de visualización de imágenes de productos. El mecanismo de defensa implementado por la aplicación elimina las secuencias de escape de directorios (../); sin embargo, lo hace de manera no recursiva (es decir, solo realiza un único reemplazo o limpieza). El reto consiste en burlar este filtro utilizando secuencias anidadas (como//) para recuperar con éxito el contenido del archivo sensible /etc/passwd.

AMBIENTE DE LABORATORIO

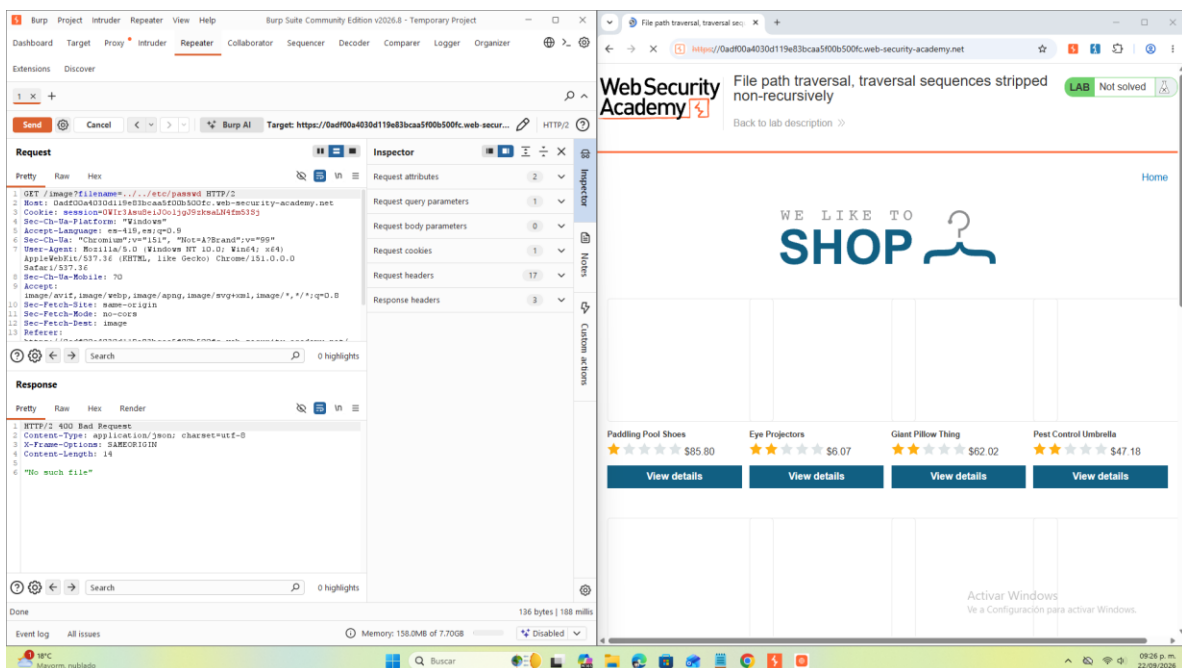


Inicio en Burp Suite y Entorno Virtualizado: Al acceder al laboratorio desde la plataforma web integrada, se intercepta el tráfico inicial con Burp Suite para analizar cómo interactúa el navegador con el servidor.

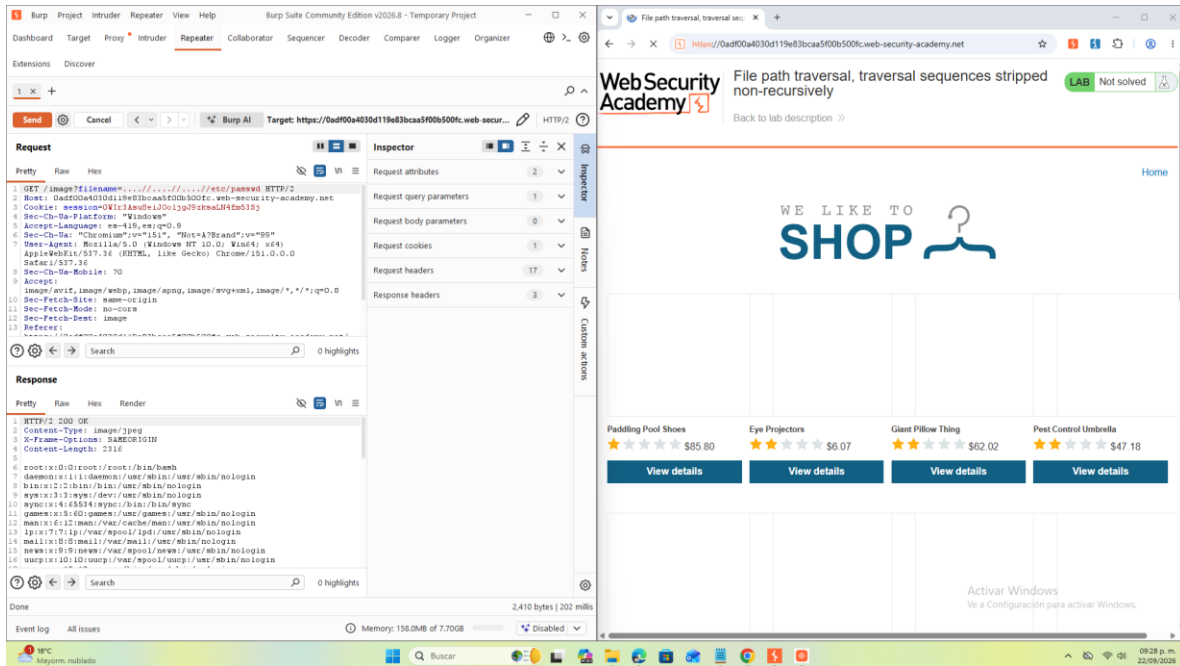


Análisis de Peticiones (Método GET): Al hacer clic en "View details" en cualquiera de los artículos de la tienda, se observa que las imágenes de los productos se cargan mediante una petición HTTP GET utilizando un parámetro de archivo (por ejemplo, `filename=blog.png`).

Uso de Burp Repeater: Se envía la petición de la imagen al módulo Repeater de Burp Suite para realizar pruebas pasivas y activas sin alterar la navegación principal del navegador.



Intentamos el acceso por la ruta `../../etc/passwd` puesta en la petición GET de una imagen y observamos que nos da un bad request



Intentamos el acceso por la ruta `....//....//....//etc/passwd` duplicando la entrada de los caracteres para obtener una secuencia anidada eliminando instancias y resolviendo la petición de manera automática, obtuvimos acceso.

ANÁLISIS DE LA VULNERABILIDAD Y FORMA DE RESOLUCIÓN

1. Comportamiento del filtro básico

Si se intenta enviar una ruta directa absoluta como `/etc/passwd` o una secuencia estándar simple como `../..//etc/passwd`, el servidor bloquea o limpia la entrada, ya que el sistema detecta y remueve las secuencias prohibidas `../`.

2. Explotación por eliminación no recursiva

Como el filtro de la aplicación es no recursivo, elimina la secuencia `../` una sola vez de la cadena de texto y une lo restante.

Esto significa que si introducimos secuencias anidadas o construidas deliberadamente como `....//`, cuando el filtro elimine la coincidencia interna (`../`), los caracteres restantes se fusionarán automáticamente para formar una secuencia `../` válida.

Ejemplo del desglose del bypass:

Entrada enviada://....//....//etc/passwd

El filtro busca y elimina la primera instancia de ../ dentro de cada bloque, dejando como resultado final concatenado: ../../../etc/passwd.

3. Ejecución en Burp Repeater

En el parámetro filename= dentro de la pestaña Repeater, reemplazamos el nombre de la imagen por la carga útil (payload) anidada:

COMANDOS UTILIZADOS

Burp Suite – Proxy (Intercept ON): Se activó la opción *Intercept on* para capturar las peticiones HTTP generadas por el navegador.

Forward: Se utilizó el botón *Forward* para permitir que la página cargara después de interceptar las solicitudes.

Observación de tráfico GET: Se identificaron múltiples peticiones de tipo **GET** hacia recursos estáticos.

Prueba de acceso a directorios: Se intentó navegar hacia el directorio raíz regresando niveles (. . /) para comprobar la estructura de directorios y posibles accesos indebidos.

Send to Repeater: Envío de la solicitud del parámetro filename al entorno de pruebas repetitivas de Burp Suite.

Manipulación de Parámetro GET (filename): Modificación del valor por secuencias anidadas no recursivas (....//) para evadir los filtros de validación de entradas.

RESULTADOS

Se identificó que la aplicación web implementa una sanitización débil basada en expresiones regulares o reemplazos simples que operan de forma no recursiva.

Se comprobó que el uso de payloads anidados (...//) permite superar el bloqueo de secuencias simples de tipo ../.

Se logró visualizar y extraer con éxito la información confidencial del archivo /etc/passwd del servidor objetivo, confirmando la vulnerabilidad de control de acceso a archivos.

CONCLUSIONES

Debilidad de los filtros basados en reemplazos únicos: Las funciones de sanitización que eliminan cadenas prohibidas (como ../) sin aplicar un bucle recursivo hasta que no queden coincidencias son altamente vulnerables a técnicas de anidación de caracteres.

Importancia de Burp Repeater: Facilita de manera exponencial la iteración rápida de payloads de prueba para comprobar fallos lógicos en los mecanismos de defensa de una aplicación web.

Mitigación adecuada: Para prevenir este tipo de vulnerabilidades, se debe evitar el uso directo de entradas de usuario en APIs del sistema de archivos. Se recomienda el uso de listas blancas estrictas (whitelisting) o funciones nativas de canonicalización de rutas (canonical paths) que validen que el archivo final esté estrictamente dentro del directorio base autorizado.